



OwnZap Infosec

We Secure You.

Blowbits Solutions LLP.

Follow Up Summary Report | Document Version :- 1.2-2025

API Penetration Testing

Disclaimer

This report is being supplied by us on the basis that it is for your benefit and information only and that, save as may be required by law or by a competent regulatory authority (in which case you shall inform us in advance), it shall not be copied, referred to or disclosed, in whole (save for your own internal purpose) or in part, without our prior written consent. The report is submitted on the basis that you shall not quote our name or reproduce our logo in any form or medium without prior written consent. You may disclose in whole this report to your legal and other professional advisers for the purpose of your seeking advice in relation to the report, provided that when doing so you inform them that:

- Disclosure by them (save for their own internal purposes) is not permitted without our prior written consent, and
- To the fullest extent permitted by law we accept no responsibility or liability to them in connection with this report. Any advice, opinion, statement of expectation, forecast or recommendation supplied or expressed by us in this report is based on the information provided to us and we believe such advice, opinion, statement of expectation, forecast or recommendation to be true. However, such advice, opinion, statement of expectation, forecast or recommendation shall not amount to any form of guarantee that we have determined or predicted future events or circumstances but shall ensure accuracy, competency, correctness or completeness of the report based on the information provided to us.

Document Details

Document	GSP API VAPT Report
Document Version	1.2-2025
Prepared By	OwnZap Infosec Pvt. Ltd.
Report Content	Detailed Summary API Penetration Testing Report
Classification	Confidential
Type of Testing	Grey-Box Testing
Testing Date	11 th August 2025
Reporting Date	14 th August 2025
Re-Assessment Date	22 nd August 2025
Test Performed By	OwnZap Team
Verified By	Puneet Matta (Lead Security Consultant)

Document Change History

Version	Date	Remarks
1.1-2025	14 th August 2025	Initial Report
1.2-2025	22 nd August 2025	Follow Up Report

Document Distribution List

Name	Organization	Designation	Email ID
Mr. Neeraj Punmiya	Blowbits Solutions LLP.		neeraj.punmiya@octagst.com

This report contains information concerning potential vulnerabilities of Blowbits Solutions LLP. assets. OwnZap recommends that special precautions be taken to protect the confidentiality of both this document and the information contained herein. OwnZap has retained and secured a copy of the report for customer reference.

Table of Contents

Contents

Introduction	05
Scope.....	07
Details of Auditing Team.....	08
Details of Audit Activities and Timelines.....	09
Methodology.....	11
Approach.....	13
Summary of Findings.....	14
Penetration Testing Tool List for Grey Box.....	16
Observation Summary	18
Comprehensive Report.....	29
List of VAPT Tests Performed.....	36
End Note.....	36

Introduction

The objective and goals of a Vulnerability Assessment and Penetration Testing (VAPT) audit revolve around identifying, analyzing, and mitigating potential vulnerabilities in an organization's IT infrastructure. These audits are critical for ensuring the security and resilience of systems, applications, and networks against cyber threats. Below are the key objectives and goals of a VAPT audit:

Objective of a VAPT Audit

The primary objective of a VAPT audit is to identify and remediate vulnerabilities within an organization's IT infrastructure to strengthen its overall security posture. This involves:

- **Risk Identification:**

Uncover security weaknesses in systems, applications, networks, and configurations.

Highlight areas that could be exploited by malicious actors.

- **Impact Analysis:**

Assess the potential impact of identified vulnerabilities on business operations, data integrity, and confidentiality.

- **Proactive Defense:**

Identify vulnerabilities before attackers can exploit them.

Validate the effectiveness of existing security controls.

- **Mitigation Guidance:**

Provide actionable recommendations for addressing and mitigating vulnerabilities.

Goals of a VAPT Audit

- **Strengthen Security Posture:**

Enhance the organization's ability to prevent, detect, and respond to cyber threats.

Build resilience against evolving attack vectors.

- **Simulate Real-World Attacks:**

Conduct penetration testing to emulate the tactics and techniques used by hackers.

Validate whether vulnerabilities can be exploited and determine their potential business impact.

- Enhance Incident Response:

Evaluate the organization's detection and response capabilities during simulated attacks.
Improve incident management procedures based on findings.

- Identify Weaknesses Across Layers:

Detect vulnerabilities at various layers, including application, network, and system levels.

- Promote Awareness and Training:

Educate stakeholders about existing security risks and the importance of robust security practices.

Foster a culture of security awareness within the organization.

- Achieve Compliance:

Align with legal, regulatory, and industry-specific security requirements.

Demonstrate commitment to securing sensitive data and systems.

- Risk Prioritization:

Categorize vulnerabilities by severity (critical, high, medium, low).

Help the organization prioritize remediation efforts based on risk levels.

- Support Continuous Improvement:

Establish a baseline for security performance and identify areas for improvement.

Encourage ongoing security assessments and proactive threat management.

Scope

The purpose of this assessment was to identify technical as well as logical vulnerabilities in the Blowbits Solutions LLP. API Penetration Testing and provide recommendations for risk mitigation that may arise on successful Review of these vulnerabilities. The idea behind this testing was to discover whether an attacker may leverage flaws in the Source to compromise the security at Blowbits Solutions LLP. The results of this API Penetration Testing will be used by Blowbits Solutions LLP., to enhance the security feature of Blowbits Solutions LLP. Important findings from the assessment were communicated to management either during or following the assessment as appropriate based on the nature and risk level of the finding. All of our findings are explained in detail in the Findings.

The following is list of the of the main tests performed on the API Testing:

1. Java de-serialization vulnerability identification and exploitation
2. Testing for XXE issues and exploitation to extract internal files from server
3. Input injection tests (SQL injection, XSS, and others)
4. Testing for arbitrary file write issues.
5. OWASP Top 10 testing

The following was the scope covered under the security audit:

Application -: <https://gsp.octagst.com/>

Asset Description -: The assessment primarily focused on GST APIs exposed via the GSP application (gsp.octagst.com). The scope also covered associated modules such as the Data Viewer (app.octagst.com), which enables authorized users to view uploaded GST transaction data.

Environment: Production

Hash File -: 92220f9e4f889ecf9505fe0e788883f9025aa07e323b20faf21617646e09193

Details of the Auditing Team

Sr. No.	Name	Designation	Email ID	Professional Qualification	Whether the resource has been listed in the Snapshot information published on CERT-In's website(Yes/No)
1.	Purvi Makwana	Security Engineer	Purvi@ownzapinfosec.co.in	CEH, ISMS 27001 LA	Yes
2.	Raj Shekhar More	Security Engineer	raj@ownzapinfosec.co.in	CEH	Yes

Details of the Audit Activities and Timelines

1. Pre-Engagement Activities

- **Define Scope and Objectives:** The client and audit team define the scope of the engagement, such as which systems, networks, and applications will be tested.
- **Sign NDA and Agreement:** Non-Disclosure Agreements (NDAs) and legal agreements are signed to ensure confidentiality.
- **Identify Testing Rules:** Establish boundaries and rules of engagement to ensure the testing does not disrupt business operations.

2. Information Gathering (Reconnaissance)

- a. **Passive Reconnaissance:** Gathering publicly available information without interacting with the target systems (e.g., WHOIS, DNS lookup, social media).
- b. **Active Reconnaissance:** Directly interacting with the target
- c. et systems to gather information (e.g., network scanning, identifying open ports, banner grabbing).
- d. **Timeline:** 1–2 days

3. Vulnerability Assessment

- a. **Automated Scanning:** Running automated vulnerability scanning tools (e.g., Burpsuite and SSLScan) to identify known vulnerabilities in the systems.
- b. **Manual Verification:** Manually verifying identified vulnerabilities to avoid false positives and assess their potential exploitability.
- c. **Timeline:** 1–3 days, depending on the system complexity.

4. Penetration Testing (Exploitation)

- a. **Exploit Vulnerabilities:** Attempting to exploit identified vulnerabilities to assess their impact and demonstrate the potential risk to the system.
- b. **Privilege Escalation:** Once access is gained, the tester attempts to escalate privileges to see how deep the attacker could penetrate the system.
- c. **Post-Exploitation:** Assessing the level of access achieved and the potential for lateral movement within the network.
- d. **Timeline:** 3–5 days

Details of the Audit Activities and Timelines

5. Reporting and Analysis

- **Findings Documentation:** Compiling and categorizing all discovered vulnerabilities, exploits, and incidents. The audit team creates a report detailing:
 - Vulnerabilities found, exploited, or not exploited.
 - The risk level (e.g., critical, high, medium, low).
 - Suggested remediation steps.
- **Risk Assessment:** Analysing the business impact of the vulnerabilities, including how they could affect business operations.
- **Timeline:** 2–5 days, depending on the complexity and the number of findings.

6. Remediation and Retesting (Optional)

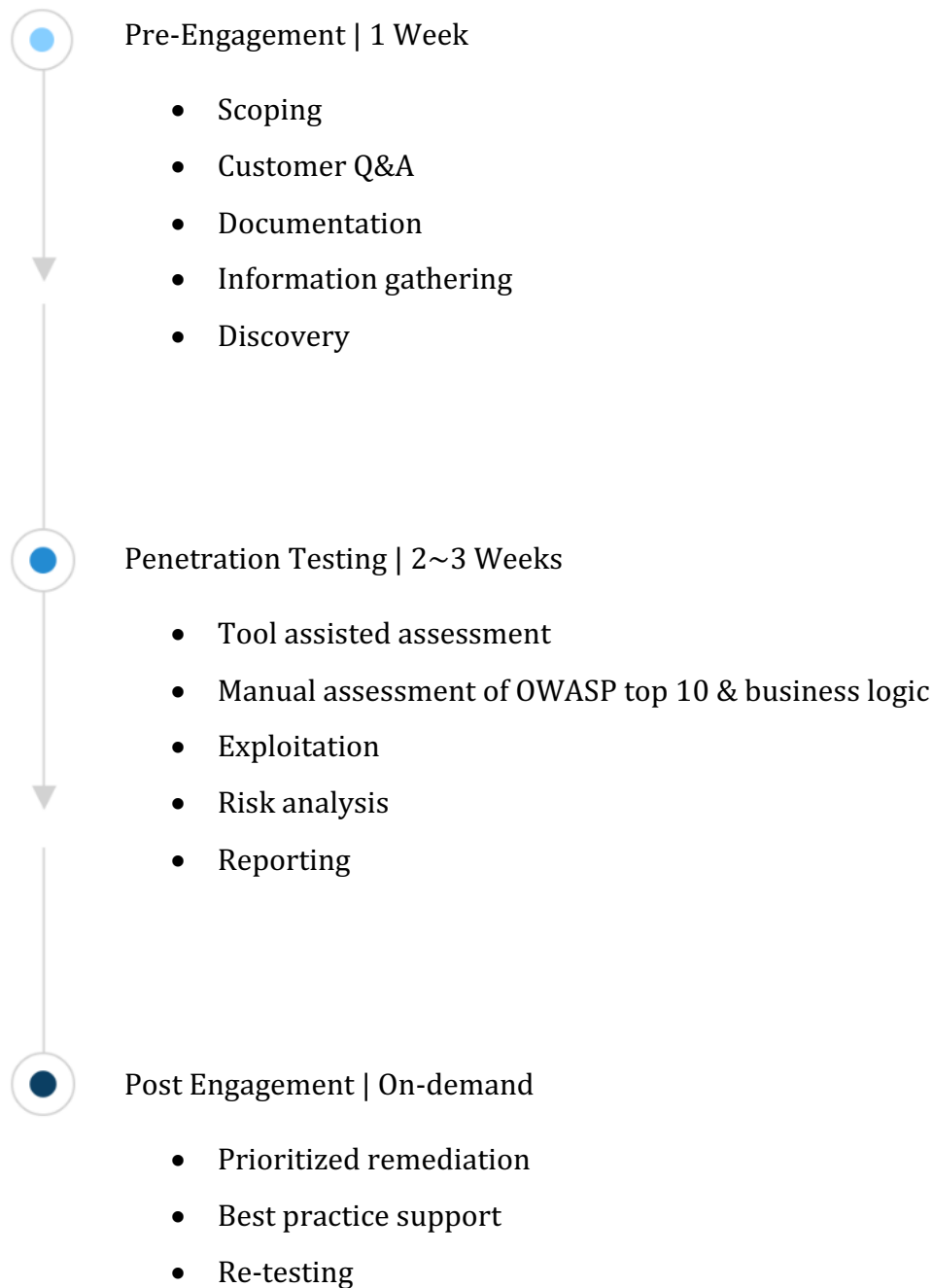
- a. **Remediation Support:** Assisting the client in addressing and fixing identified vulnerabilities, either by providing technical advice or detailed steps.
- b. **Retesting:** After fixes are implemented, retesting to verify that vulnerabilities have been successfully mitigated.
- c. **Timeline:** 1–2 weeks for remediation and 2–3 days for retesting.

7. Post-Engagement Activities

- a. **Debriefing:** A final review meeting to discuss findings, remedial actions, and potential follow-up activities.
- b. **Lessons Learned:** Sharing insights and best practices for the organization's future security posture.
- c. **Documentation:** Providing the final audit report and any supporting documentation.
- d. **Timeline:** 1–2 days.

Methodology

The test was done according to penetration testing best practices. The flow from start to finish is listed below.



Risk Factors

Each finding is assigned two factors to measure its risk. Factors are measured on a scale of 3 (low) through 0 (very high).

Impact

This indicates the finding's effect on technical and business operations. It covers aspects such as the confidentiality, integrity, and availability of data or systems; and financial or reputational loss.

Likelihood

This indicates the finding's potential for exploitation. It takes into account aspects such as skill level required of an attacker and relative ease of exploitation.

Criticality Definition

The category describes the risk level of the vulnerability which is derived as follows. These risk categories have been defined by OwnZap vast experience in API Penetration Testing, on the basis of available Common Vulnerabilities and Exposures (CVEs):

High Risk	Weakness in controls that represent exposure to the organization or risks that could seriously compromise the control framework, data integrity and/or operational efficiency. These risks need to be addressed with utmost priority.
Medium Risk	Potential weakness in controls, which could develop into an exposure. Or Issues that represent areas of concern and may impact controls. They should be addressed reasonably promptly.
Low Risk	Potential weakness in controls, which in combination with other weakness can develop into exposure. Suggested Improvements not immediately/directly affecting controls.
Info Risk	Weakness mentioned under this section are informational and are best practices. Either these weaknesses cannot be exploited directly or are very difficult to exploit due to multiple constraints.

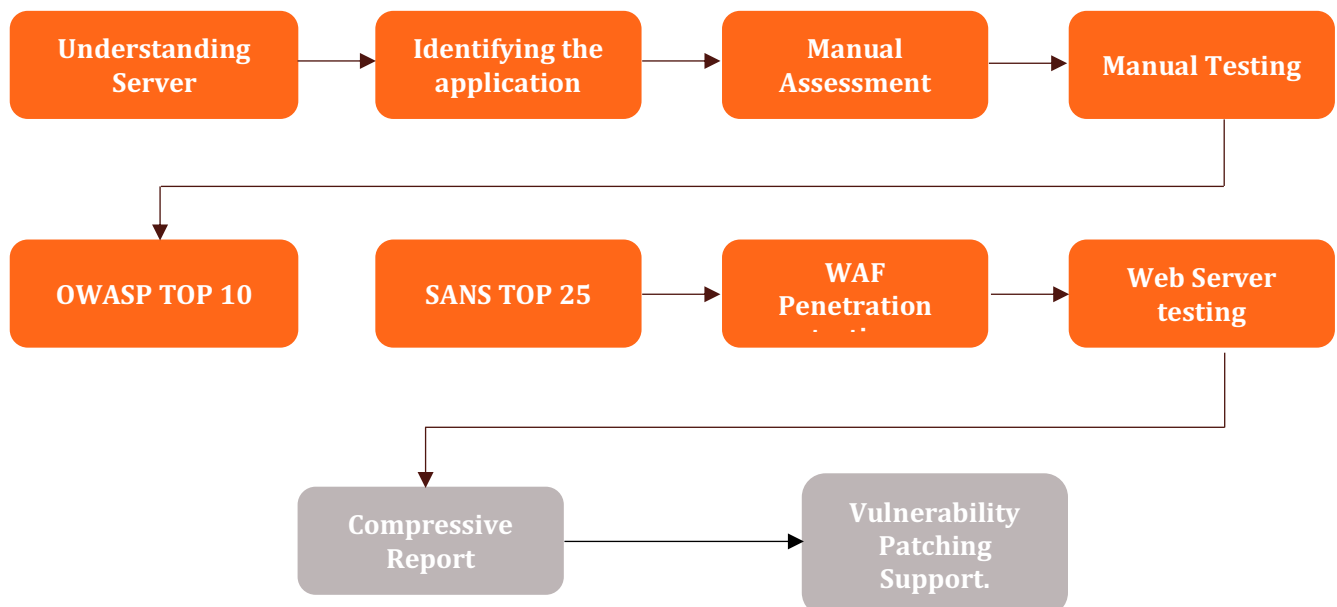
Approach

The API Penetration Testing was conducted as a Grey-Box, implying that the testing team was only given the basic access to the API for available privileges, this testing was done to simulate the viewpoint of a completely external attack and also find the potential vulnerabilities on the Blowbits Solutions LLP. API Penetration Testing.

Ownzap Infosec conducted the tests against industry best practices like Open API Security Project and test cases generated based on Ownzap vast experience in the field of API Penetration Testing.

The testing was done in a way to resemble a malicious attack targeting the Blowbits Solutions LLP. API Penetration Testing with goal to:

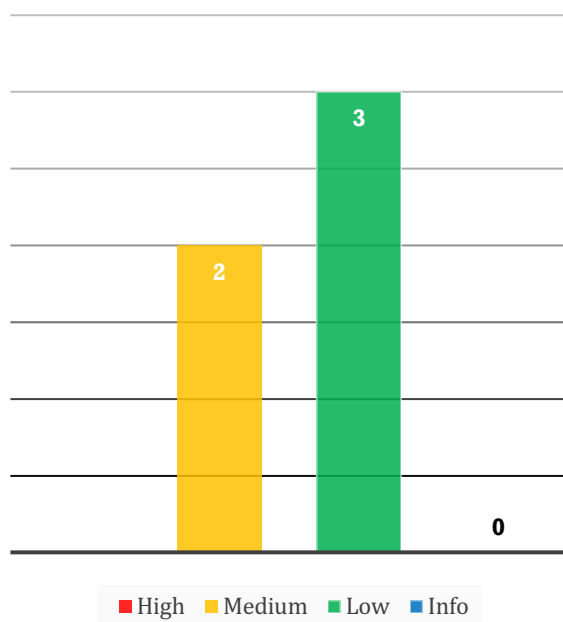
- To determine the impact of a security breach.
- Vulnerability of confidentiality, integrity and availability of protected data.



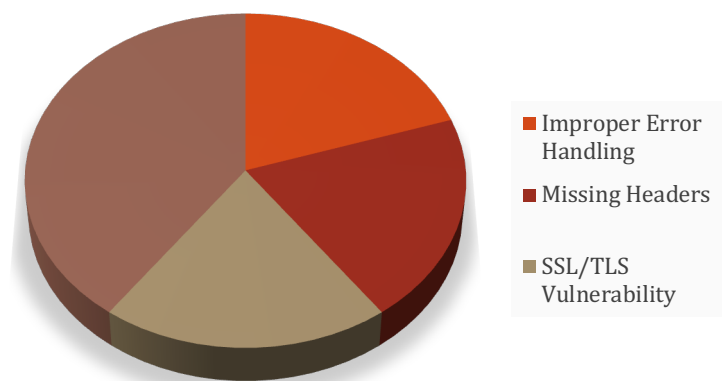
Summary Of Findings

The following charts group discovered vulnerabilities by OWASP and SANS Top 25 vulnerability type and by overall estimated severity.

By Criticality



By Vulnerability Type



Blowbits Solutions LLP. provided a demonstration that was purposely vulnerable for the purposes of benchmarking their security solution. A Grey-Box penetration test of the Blowbits Solutions LLP. API was conducted in order to assess the efficacy of its tool against the following in-scope vulnerability types: (1) SQL Injection, (2) Java de-serialization, (3) Remote Code Execution, and (4) Arbitrary File Write and Many More Vulnerabilities. The target of the assessment covered 01. <https://gsp.octagst.com/> researchers conducted this penetration test between August 11th 2025 and August 14th 2025 then re-assessment between 21st August to 22nd August 2025.



This penetration test was a manual exploitation of API vulnerabilities without its security tool and then trying to reproduce if the attack is possible once the security tool is installed and configured. The researchers leveraged tools to facilitate their work, however, the majority of the assessment involved manual analysis.

Analysis

The issues identified represent the following trend during our analysis:
Blowbits Solutions LLP. API Testing With tool in place.

1. A Team Identified Improper Input Validation.
2. A Team Identified Improper Error Handling.
3. A Team Identified Missing Security Headers.
4. A Team Identified SSL/TLS vulnerability.
5. A Team Identified Server Version Disclosed.

Penetration Testing Tools List for Grey Box

Sr. No.	Tool Name	Description
1.	Burp suite	Burp Suite is a proxy program that enables us to track, examine, and alter requests made by our browsers before they are forwarded to a distant server. Burp Suite is a prominent web application security solution. It gives us the ability to manually test for vulnerabilities, intercepts HTTP messages, and change a message's body and header. Burp Suite is a comprehensive framework that may be used to carry out several activities, including: • Web crawling. • Web application testing, both manually and automatically. • Analysis of web applications. • Vulnerability detection
2.	SSLScan	SSLScan queries SSL services, such as HTTPS, in order to determine the ciphers that are supported. SSLScan is designed to be easy, lean and fast. The output includes preferred ciphers of the SSL service, the certificate and is in text and XML formats.
3.	TestSSL	testssl.sh is a free command line tool which checks a server's service on any port for the support of TLS/SSL ciphers, protocols as well as recent cryptographic flaws and more. Key features • Clear output: you can tell easily whether anything is good or bad • Ease of installation: It works for Linux, Darwin, FreeBSD and MSYS2/Cygwin out of the box: no need to install or configure something, no gems, CPAN, pip or the like. • Flexibility: You can test any SSL/TLS enabled and STARTTLS service, not only web servers at port 443 • Toolbox: Several command line options help you to run YOUR test and configure YOUR output • Reliability: features are tested thoroughly • Verbosity: If a particular check cannot be performed because of a missing capability on your client side, you'll get a warning.

Sr. No.	Tool Name	Description
4.	SqlMap	SQLMAP allows you to automate the process of identifying and then exploiting SQL injection flaws and subsequently taking control of the database servers. In addition, SQLMAP comes with a detection engine that includes advanced features to support penetration testing.
5.	Recon-ng.py	Recon-ng is a free and open-source tool that we can download and use without charge. Recon-ng is a tool for gathering information and assessing the vulnerability of web applications. Pentesters will find it easier to work with Recon-ng because it can target a single domain and find all of its subdomains.
6.	Scrapy.py	Scrapy is a fast high-level web crawling and web scraping framework, used to crawl websites and extract structured data from their pages. It can be used for a wide range of purposes, from data mining to monitoring and automated testing.
7.	Dirbuster	Dirbuster is used once you have scanned an IP address and found any vulnerabilities. DirBuster will help you map out the application. Building a directory of the target site is useful in finding as many potential points of entry to the target.

Observation Summary

Sr. No.	Vulnerabilities	Severity	CVE/CWE	Recommendation	Reference	New/Repeat	Status
1.	Improper Error Handling	Medium	CWE-755	Implement Separation of privileges	Link	New	Closed
2.	Improper Input Validation	Medium	CWE-20	Implement strict input validation	Link	New	Closed
3.	Missing CSP Header	Low	CWE-693	Implement CSP Header	link	New	Open
4.	Server is Vulnerable to Lucky 13Attack	Low	CVE-2013-0169	Disabling CBC Mode Cipher Suites	Link	New	Closed
5.	Server Version Disclose	Low	CWE-200	Remove version details from error messages	Link	New	Closed

Comprehensive Report

This section has the list of detailed test cases run by our cyber security experts on the given application. Test cases are grouped as general test cases and specific test cases. General test cases are common for all applications and specific test cases are specially for each domain (E-Commerce, FinTech, Healthcare, Telecom etc.) and also depends on the business logic.

The section will have all the N number of test cases each with Objective, Methodology and Result run on the application irrelevant of the result.

List of VAPT Tests Performed

The following lists of tests are suggestive & not limited to the ones listed. Most importantly, every test case has multiple sub-test cases ranging from a few to sometimes 1000+ sub tests.

Additional test cases will be performed based on factors such as:

1. Technology Stack
2. Server-Side Programming Language, Front-end frameworks
3. Framework/CMS/APIs
4. Type of application (Payment integrations, external integrations)

OWASP TOP 10

OWASP Top 10
Insecure Authentication/Authorization
Insecure Communication
Inadequate Supply Chain Security
Inadequate Privacy Controls
Improper Credential Usage
Insufficient Input/Output Validation
Security misconfiguration
Insufficient Cryptography
Insecure Data Storage
Insufficient Binary Protections

SANS TOP 25

SANS TOP 25
Untrusted Search Path
Unrestricted Upload of File with Dangerous Type
Improper Certificate Validation
Missing Release of Resource after Effective Lifetime
Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')
Incorrect Permission Assignment for Critical Resource
Improper Input Handling
Information Exposure
Improper Restriction of Operations within the Bounds of a Memory Buffer
Out-of-bounds Read
Improper Authentication
Improper Privilege Management
Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')
Use After Free
Integer Overflow or Wraparound
Cross-Site Request Forgery (CSRF)
Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection')
Out-of-bounds Write
NULL Pointer Dereference
Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')
Improper Restriction of XML External Entity Reference

SANS TOP 25

Improper Control of Generation of Code ('Code Injection')

Use of Hard-coded Credentials

Uncontrolled Resource Consumption

Deserialization of Untrusted Data

Other Test Cases - 174

Sr. No.	Other Tests	Severity
1.	OS Command Injection	High
2.	SQL Injection (Second Order)	High
3.	XML External Entity Injection	High
4.	LDAP Injection	High
5.	XPath Injection	High
6.	XML Injection	High
7.	ASP.NET Debugging Enabled	High
8.	DoS Locking Customer Accounts	Medium
9.	DoS Buffer Overflows	Medium
10.	Storing too much data in session (DoS)	High
11.	Writing user-provided data to disk (DoS)	High
12.	HTTP Insecure methods available on Server	High
13.	Out of band resource load (HTTP)	High
14.	File path manipulation	High
15.	Server-site JavaScript code injection	High
16.	Perl code injection	High
17.	Ruby code injection	High
18.	Python code injection	High
19.	Expression Language injection	High
20.	Unidentified code injection	High
21.	Server-side template injection	High
22.	SSL injection	High
23.	Stored XSS	High
24.	HTTP response header injection	High
25.	Reflected XSS	High
26.	Client-side template injection	High
27.	DOM-based XSS	High
28.	Reflected DOM-based XSS	High
29.	Stored DOM-based XSS	High
30.	DOM-based JavaScript Injection	High
31.	Reflected DOM-based JavaScript Injection	High
32.	Stored DOM-based JavaScript Injection	High
33.	Path-relative style sheet import	Information
34.	Client-side SQLi (DOM-based)	High
35.	Client-side SQLi (Reflected DOM-based)	High
36.	Client-side SQLi (Stored DOM-based)	High
37.	WebSocket Hijacking (DOM-based)	High
38.	WebSocket Hijacking (Reflected DOM-based)	High
39.	WebSocket Hijacking (Stored DOM-based)	High
40.	Local Path Manipulation (DOM-based)	High
41.	Local Path Manipulation (Reflected DOM)	High
42.	Local Path Manipulation (Stored DOM-based)	High

Sr. No.	Other Tests	Severity
43.	Client-side XPATH Injection (DOM-based)	Low
44.	Client-side XPATH Injection (Reflected DOM)	Low
45.	Client-side XPATH Injection (Stored DOM)	Low
46.	Client-side JSON Injection (DOM-based)	Low
47.	Client-side JSON Injection (Reflected DOM)	Low
48.	Client-side JSON Injection (Stored DOM-based)	Low
49.	Flash cross-domain policy	High
50.	Cross-origin resource sharing	Information
51.	Cross-origin resource sharing (arbitrary)	High
52.	Cross-origin resource sharing (encrypted)	Low
53.	Cross-origin resource sharing (all sub-domains)	Low
54.	Cross-site Request Forgery (CSRF)	Medium
55.	Content type is not specified	Information
56.	SSL certificate	Medium
57.	Unencrypted communications	Low
58.	Strict transport security not enforced	Low
59.	Mixed content	Information
60.	SMTP header injection	Medium
61.	Cleartext submission of password	High
62.	External service interaction (DNS)	High
63.	External service interaction (HTTP)	High
64.	External service interaction (SMTP)	Information
65.	Referrer dependent response	Information
66.	Spoofable client IP address	Information
67.	User-agent dependent response	Information
68.	Password returned in a later response	Medium
69.	Password submitted using GET method	Low
70.	Password returned in URL query string	Low
71.	SQL statement in request parameter	Medium
72.	Cross-domain POST	Information
73.	ASP.NET ViewState without MAC Enabled	Low
74.	XML entity expansion	Medium
75.	Long redirection response	Information
76.	Serialized object in HTTP message	High
77.	Duplicate cookies set	Information
78.	WebSocket Hijacking (DOM-based)	High
79.	WebSocket Hijacking (Reflected DOM-based)	High
80.	WebSocket Hijacking (Stored DOM-based)	High
81.	Local Path Manipulation (DOM-based)	High
82.	Local Path Manipulation (Reflected DOM)	High
83.	Local Path Manipulation (Stored DOM-based)	High
84.	Client-side XPATH Injection (DOM-based)	Low
85.	Client-side XPATH Injection (Reflected DOM)	Low
86.	Client-side XPATH Injection (Stored DOM)	Low
87.	Client-side JSON Injection (DOM-based)	Low

Sr. No.	Other Tests	Severity
88.	Client-side JSON Injection (Reflected DOM)	Low
89.	Client-side JSON Injection (Stored DOM-based)	Low
90.	Flash cross-domain policy	High
91.	Cross-origin resource sharing	Information
92.	Cross-origin resource sharing (arbitrary)	High
93.	Cross-origin resource sharing (encrypted)	Low
94.	Cross-origin resource sharing (all sub-domains)	Low
95.	Cross-site Request Forgery (CSRF)	Medium
96.	SMTP header injection	Medium
97.	Cleartext submission of password	High
98.	External service interaction (DNS)	High
99.	External service interaction (HTTP)	High
100.	External service interaction (SMTP)	Information
101.	Referrer dependent response	Information
102.	Spoofable client IP address	Information
103.	User-agent dependent response	Information
104.	Password returned in a later response	Medium
105.	Password submitted using GET method	Low
106.	Password returned in URL query string	Low
107.	SQL statement in request parameter	Medium
108.	Cross-domain POST	Information
109.	ASP.NET ViewState without MAC Enabled	Low
110.	XML entity expansion	Medium
111.	Long redirection response	Information
112.	Serialized object in HTTP message	High
113.	Duplicate cookies set	Information
114.	Input returned in response (stored)	Information
115.	Input returned in response (reflected)	Information
116.	Suspicious input transformation (reflected)	Information
117.	Suspicious input transformation (stored)	Information
118.	Open redirection (stored)	Low
119.	Open redirection (reflected)	Medium
120.	Open redirection (DOM-based)	Low
121.	Open redirection (Stored DOM-based)	Low
122.	Open redirection (Reflected DOM-based)	Medium
123.	SSL cookie without secure flag set	Medium
124.	Cookie scoped to parent domain	Low
125.	Cross-domain referrer leakage	Information
126.	Cross-domain script include	Information
127.	Cookie without HTTPOnly flag set	Information
128.	Session token in URL	Information
129.	Password field with autocomplete enabled	Information
130.	Password value set in cookie	Information
131.	Browser cross-site scripting disabled	Low
132.	HTTP TRACE method is enabled	Medium

Sr. No.	Other Tests	Severity
133.	Cookie manipulation (DOM-based)	Low
134.	Cookie manipulation (reflected DOM-based)	Low
135.	Cookie manipulation (DOM-based)	Medium
136.	Ajax request header manipulation (DOM-based)	Medium
137.	Ajax request header manipulation (reflected)	Low
138.	Ajax request header manipulation (stored DOM)	Information
139.	Denial of service (DOM-based)	Information
140.	Denial of service (reflected DOM-based)	Information
141.	Denial of service (stored DOM-based)	Information
142.	HTML5 web message manipulation DOM-based	Information
143.	HTML5 web message manipulation (reflected)	Information
144.	HTML5 web message manipulation (stored DOM)	Low
145.	HTML5 storage manipulation (DOM-based)	Medium
146.	HTML5 storage manipulation (reflected DOM)	Low
147.	HTML5 storage manipulation (stored DOM)	Low
148.	Link manipulation (DOM-based)	Low
149.	Link manipulation (reflected DOM-based)	Low
150.	Link manipulation (stored DOM-based)	Low
151.	Link manipulation (reflected & stored)	Information
152.	Document domain manipulation (DOM-based)	Medium
153.	Document domain manipulation reflected DOM	Medium
154.	Document domain manipulation (stored DOM)	Medium
155.	DOM data manipulation (DOM-based)	Information
156.	CSS Injection (reflected & stored)	Medium
157.	Client-side HTTP parameter pollution (reflected)	Low
158.	Client-side HTTP parameter pollution (Stored)	Low
159.	Form action hijacking (reflected)	Medium
160.	Form action hijacking (stored)	Medium
161.	Database connection string disclosed	Medium
162.	Source code disclosure	Low
163.	Directory listing	Information
164.	Email addresses disclosed	Information
165.	Private IP addresses disclosed	Information
166.	Social security numbers disclosed	Information
167.	Credit card numbers disclosed	Information
168.	Private key disclosed	Information
169.	Cacheable HTTPS response	Information
170.	Base64 encoded data in parameter	Information
171.	Multiple content types specified	Information
172.	HTML does not specify charset	Information
173.	HTML uses unrecognized charset	Information
174.	Content type incorrectly stated	Low

Conclusions

The assessment revealed five security issues, including improper error handling, input validation flaws, missing security headers, cryptographic weakness (Lucky 13 attack), and server version disclosure. These vulnerabilities may expose the application to potential exploits or information leakage. Addressing these findings will enhance the application's overall security posture and align it with industry best practices.